framework-eu-data-protection_en). To do so, they must ensure that only authorized employees can access sensitive financial records, access is logged, reviewable, and revocable, and temporary access is granted only when justified and expires automatically.

As we've seen, when using ACLs or groups, employees are assigned static roles like Finance Manager or Auditor. Over time, as people change roles, they tend to accumulate excess permissions because removing people from groups (a process called *baselining*) is easy to overlook or miss. Consequently, auditors can't easily answer the question "who has access to what?" leading to problems showing compliance with regulations.

Similarly, using ACLs for individual customer records leads to thousands or even millions of lists that must be scanned to audit access to comply with GDPR. Automatically removing temporary access requires bespoke systems that are costly to build and hard to maintain. Static authorization makes regulatory compliance impractical.

In contrast, dynamic authorization allows auditors to review policies to check for compliance and use system logs to ensure the policies are working as they should.

1.2.6 Security

The security challenges of static authorization are mostly fallout from the other problems we've discussed. We count on authorization systems to protect our most valuable and sensitive assets, ensure customer data is safe, and make it difficult for hackers to harm the organization. Static lists are notorious for leaving principals with permissions they no longer require. Stories of employees who still have access to critical systems long after they've left the company are common.

As discussed earlier, more organizations are turning to Zero Trust architectures to protect themselves. Zero Trust requires checking each access request. With static authorization tools, we can implement only some of the best practices for Zero Trust.